

**WHITE
PAPER**

Novembre
2025



A cura di
BIAGIO POLISENO

STANDARD DI GESTIONE

DEI DATI DEI DIPENDENTI

DOPO L'AI ACT

WWW.ICTSECURITYMAGAZINE.COM

Abstract

Lo scopo di questo lavoro è di sintetizzare il quadro normativo sulla gestione dei dati dei dipendenti dopo l'adozione dell'AI ACT. I dipendenti sono dei portatori di interesse interni alle aziende la cui tutela ha ricadute su tutta la popolazione, rendendoli un punto di vista strategico, nonostante siano stati spesso trascurati dal legislatore europeo.

Il punto di partenza è quello della strategia europea in materia di intelligenza artificiale, dove emerge un'attenzione su due punti: il primo quello del diventare un "polo regolatore", il secondo quello di tutelare la propria sicurezza informatica. Questo approccio viene calato nell'ordinamento italiano, già ampiamente normato da statuto dei lavoratori e decreto trasparenza, che negli anni è stato arricchito dal legislatore europeo e l'IA Act rappresenta l'ultimo passo; in particolare, ci si sofferma sulle interazioni con il GDPR - l'altro regolamento in materia - e sulle procedure di monitoraggio introdotte nel capo IX.

Le criticità che l'ultimo regolamento va a toccare sono anche oggetto di diverse certificazioni ISO, che possono fornire un modello per risolvere il problema dell'affidabilità degli algoritmi e delle intelligenze artificiali, una sorta di "problema zero" dell'automazione. Nelle conclusioni si propone proprio la soluzione a questo problema come prospettiva per analizzare le attuali normative - e anche le prossime - facendo emergere proprio le tutele dei lavoratori e il coinvolgimento delle loro organizzazioni nel processo di costruzione della fiducia verso le nuove tecnologie

Indice

About the Autor

Introduzione: contesto e scopo di questa ricerca

- I.1 Intelligenza Artificiale e Geopolitica: Unione Europea come polo regolatore? Pag. 5
- I.2 La cybersecurity, una componente fondamentale Pag. 6

Capitolo 1

- 1.0 Premessa Pag. 10
- 1.1 Il principio della limitazione delle finalità Pag. 11
- 1.2 Obblighi informativi per il datore di lavoro Pag. 14
- 1.3 Quadro complessivo e l'introduzione dell'IA ACT Pag. 17

Capitolo 2

- 2.0 Premessa Pag. 20
- 2.1 I principi della cybersecurity nella regolamentazione europea Pag. 22
- 2.2 I controlli e le autorità di vigilanza nel quadro post AI ACT Pag. 27
 - 2.2.1 Il capo IX dell'AI Act, le procedure di monitoraggio Pag. 28
 - 2.2.2 Quali sono le autorità sull'IA in Italia? Pag. 30
- 2.3 Il modello delle certificazioni ISO e della direttiva NIS2 Pag. 32

Conclusioni

Bibliografia

About The Author



Dott. Biagio Polisenno

Biagio Polisenno è nato a Bari il 21 agosto 2000. Dopo essersi trasferito a Roma, ha intrapreso un percorso accademico internazionale, conseguendo con lode una laurea triennale in Affari Internazionali presso la John Cabot University nel dicembre 2021. A marzo 2024 ha completato con il massimo dei voti la laurea magistrale in Scienze dell'amministrazione e della politica pubblica presso Sapienza – Università di Roma, con una tesi sul algorithmic management e il ruolo del sindacato nella regolazione dell'intelligenza artificiale nei contesti lavorativi.

Parallelamente alla formazione accademica, ha maturato esperienze in ambito amministrativo, redazionale e universitario, con tirocini in contesti di ONG e aziende. Durante la pandemia ha ricoperto il ruolo di Covid Manager, coordinando l'applicazione dei protocolli di sicurezza durante eventi sportivi organizzati da l'ACI.

Nel 2025 ha concluso con lode il master di II livello in Informatica giuridica, diritto delle nuove tecnologie alla Sapienza, presentando una tesi dedicata agli standard di gestione dei dati dei dipendenti alla luce del Regolamento europeo sull'intelligenza artificiale (AI Act).

Introduzione

CONTESTO E SCOPO DI QUESTA RICERCA

I.1 **Intelligenza Artificiale e Geopolitica: Unione Europea come polo regolatore?**

Negli ultimi anni il tema dell'Intelligenza Artificiale (IA) ha preso sempre più importanza nel dibattito politico ordinario, seppur con alti e bassi, uscendo dalla zona di quegli argomenti che interessa a pochi addetti ai lavori. Sicuramente una causa dietro questo fenomeno è da trovarsi nel potenziale impressionante che questa tecnologia sta dimostrando di avere, ne sono un esempio gli ultimi sviluppi delle IA "generaliste" - cioè in grado di fare più compiti superando la necessità di una iper specializzazione - ma non è l'unica. Infatti, ci sono diverse tecnologie che nell'ultimo decennio hanno visto passi in avanti significativi come le reti *blockchain*, la realtà aumentata legata al *metaverso* o anche il settore della produzione energetica sostenibile. Quello che ha coltivato l'interesse nella rivoluzione IA è il suo ruolo strategico sia nella possibilità di portare i livelli di produttività ad un nuovo balzo, grazie alla capacità di concepire soluzioni e tattiche fuori dalla portata di una mente umana, e l'integrazione che questa tecnologia ha con la data economy che è senza dubbio diventata uno dei motori portanti delle economie dei paesi più avanzati, inclusa l'Italia.

Al fine di comprendere gli scopi e le preoccupazioni degli attori coinvolti è necessario analizzare questo sviluppo tecnologico contestualizzandolo all'interno della realtà in cui è emerso. In questa partita non giocano un ruolo solo grandi e piccole aziende di sviluppo informativo, ma operano anche gli attori statali. Non c'è da stupirsi; è da dopo la pandemia gli interessi pubblici sono tornati a pesare sempre di più, portando gli stati a intervenire direttamente nell'economia e nei vari livelli di *governance* - intesa proprio come gestione degli interessi vivi della società.

Il punto di vista privilegiato dell'analisi condotta in questa tesi è quello europeo. Il motivo è da trovarsi nel fatto che in una partita di queste proporzioni, in cui gli attori in gioco sono Stati Uniti, Cina e Russia, gli stati europei sarebbero destinati all'irrilevanza se non si coordinassero tramite l'Unione Europea. Questo è diventato particolarmente evidente nello sviluppo geopolitico degli ultimi anni, caratterizzato dallo scoppio di nuovi conflitti, tensioni, rotture e in generale dal declino di quel clima di collaborazione globale che aveva caratterizzato gli anni successivi alla fine della guerra fredda. La vicinanza con la Russia e la Cina, e dall'elezione di Donald Trump anche quella con gli Stati Uniti, inizia a far emergere delle conseguenze negative che quindi vanno soppesate rispetto ai benefici; in altre parole, è necessaria una rivalutazione della strategia internazionale europea.

È possibile vedere come questo nuovo contesto si rifletta anche nella partita per lo sviluppo delle IA. L'ultimo esempio è stato quando in Cina il fondo finanziario *High-Flyer* ha rilasciato il suo modello di ChatBot "DeepSeek¹" in aperta competizione con l'americano ChatGPT rilasciato da OpenAI. Il semplice ingresso della Cina su questo mercato con un modello paragonabile a quello statunitense ha fatto impazzire i mercati portando a centinaia di miliardi di dollari di perdite. Si prepara una lunga stagione di dazi, restrizioni d'accesso ed altre forme di protezionismo. Questa tesi non è il luogo per confrontare i vari modelli di IA, svelare la speculazione finanziaria alle spalle di queste aziende o approfondire altri temi affascinanti che girano attorno a questa tecnologia; invece, è fondamentale delineare quale sia la posizione che l'UE si stia ritagliando in questa competizione storica che è effettivamente unica nello scenario globale.

I.2 La cybersecurity, una componente fondamentale

L'UE si presenta come una sorta di "polo regolatore" che non promuove sempli-

¹ in cinese: 深度求索, shēn dù qiú suǒ

cemente lo sviluppo di modelli in competizione con gli altri, ma un intero approccio alternativo che possa andare a misurarsi non solo sull'efficacia di queste tecnologie ma sul loro impatto positivo. Proprio come per tutte le regolamentazioni attorno al mercato unico, la strategia europea consiste nel fare leva sulla propria superiorità in tema di valori etici e sociali. In materia di IA si parla proprio di "Intelligenze Sociali per il bene comune"² e negli ultimi anni il legislatore comunitario si è concentrato sul far emergere un regolamento che andasse subito a chiarire i limiti per questa tecnologia tenendo a mente anche la necessità di innovazione. Questo iter si è tradotto nella pubblicazione del regolamento europeo sull'intelligenza artificiale, anche noto come AI Act, nell'estate del 2024.

Abbiamo già detto come le IA si vadano a integrare in un ecosistema economico informatico, digitale e basato sui dati, ma all'interno di un sistema conflittuale va tenuto a mente anche la necessità di proteggere questa infrastruttura da parte di attacchi di guerra ibrida e digitale - di cui il nostro paese è già stato soggetto in passato. All'interno di questa competizione non ci si può aspettare uno spirito sportivo e leale - forse nemmeno gli stati europei possono fregiarsi di averlo - e quindi diventa necessario inserire nella strategia europea una terza componente fondamentale, quella della *cybersecurity*.

Come vedremo nel corso della tesi, la sicurezza informatica o cybersicurezza rappresenta un vero e proprio approccio paradigmatico fondamentale per la regolamentazione. Questo perché si tratta di un metodo complesso volto a costruire interventi specifici per ogni singola organizzazione, partendo dai rischi e dalle opportunità particolari. Questa prassi traspare non solo all'interno dell'AI Act, ma anche in tutti gli interventi normativi europei precedenti riguardo il mercato digitale. In particolare, si fa attenzione sia alle minacce esterne che emergono dal contesto internazionale sia a quelle interne dovute alla oggettiva novità e difficoltà tecnica. Il principio fondamentale, in ultima analisi, non è quello di tutelare la tecnologia in sé per sé, ma quello di tutelare il primato come mercato sicuro che tutela i propri cittadini. Non si parla solo della *cybersecurity* nel senso di pro-

² Artificial Intelligence For Social Good" abbreviato in AI4SG. L. FLORIDI, *Etica dell'intelligenza artificiale. Sviluppi, opportunità, sfide*, Raffaello Cortina Editore, 2022, p. 300. Citato in Tebano L. (2023) "Poteri datoriali e dati biometrici nel contesto dell'AI Act".

tezione da attacchi hacker, ma come costruzione di un'infrastruttura sicura. Un approccio già presente con il regolamento sulla gestione dei dati personali, l'ormai celebre GDPR.

Ed è proprio il concetto di tutela che diventa il filo conduttore di questa ricerca, il cui fine è quello di studiare e sintetizzare quale sia il quadro complessivo che è emerso a seguito dell'ultimo regolamento in materia di IA. La lente specifica con cui è stata fatta questa analisi è quella del rapporto di lavoro e della base giuslavorista. Il motivo è che il ruolo dei lavoratori in queste dinamiche sociali non è secondario. Sono i lavoratori che fanno materialmente funzionare le aziende, le pubbliche amministrazioni e ogni altro aspetto della nostra economia, incluso lo sviluppo delle IA. Una delle applicazioni con più alto potenziale per questa tecnologia prende forma all'interno della gestione algoritmica, o *algorithmic management*, in cui il processo automatizzato è quello di organizzazione del lavoro, standardizzazione e valutazione dei processi produttivi. Non si tratta di una prospettiva futura, ma della realtà già presente per aziende colossali e critiche nell'economia nazionale e globale.

I lavoratori sono dei portatori di interesse che nella tutela del diritto alla privacy e dei dati personali tendono a non emergere quanto altre figure, come per esempio i consumatori. Questo è un'opportunità persa, che questa tesi cerca di cogliere. Le tutele dei lavoratori sono un aspetto altrettanto strategico che ha un impatto quotidiano sulla vita di tutti.

CAPITOLO 1

**PROFILO GIURIDICO
ITALIANO DELLA
GESTIONE DEI DATI
DEI LAVORATORI**

1.0 Premessa

La protezione dei dati personali non è una materia esclusivamente tecnica. Al contrario, parlando di un diritto nel senso più soggettivo - cioè come “interessi giuridicamente protetti³” dell'individuo - ha senso partire proprio da un approccio giuridico, e in particolare giuslavorista. Per questo motivo inizieremo dall'analizzare quali strumenti giuridici presenta l'ordinamento italiano prima di capire l'impatto dell'introduzione di sistemi automatizzati. L'argomento è quanto più lontano dall'essere statico. Non solo la tecnologia avanza inesorabilmente andando a mutare - a volte rivoluzionare - le condizioni oggettive in cui viviamo, ma a questo si aggiunge anche un continuo tentativo di regolamentare e legiferare la materia. Non bisogna arrivare alla conclusione disfattista che allora questo studio sia inutile, perché questo è l'unico modo per comprendere sia i dettagli dell'evoluzione sia i principi essenziali che sopravvivendo alle trasformazioni, anche quelle più radicali, vanno a definire i tratti di riconoscimento della nostra società. L'ultimo sviluppo in materia è stato l'IA Act dell'Unione Europea ma prima di parlarne nel dettaglio è necessario analizzare prima i fondamenti e gli strumenti della materia giuslavorista.

In sintesi, sono due gli elementi fondamentali. Il primo è il principio con il quale si procede alla limitazione dei poteri datoriali e in particolare quello dell'iniziativa economica; il secondo è lo strumento dell'imposizione di obblighi informativi, sia nella dimensione di quando si applicano ma anche di come essi si strutturano. Accostiamo, cioè un'analisi teorica dei ragionamenti e una tecnica degli strumenti.

³ Rechte sind rechtliche geschützte Interessen” è la nota definizione di Jhering del diritto soggettivo. Menzionata da diverse fonti tra cui l'enciclopedia Treccani e la relazione al corso di formazione sul Riparto di giurisdizione, organizzato da Scuola superiore della Magistratura e Ufficio studi della giustizia amministrativa, Roma, Tar Lazio, 16 marzo 2017, consultabile a questo link: <https://tinyurl.com/mwru4pfz>

1.1 Il principio della limitazione delle finalità

Il diritto del lavoro del nostro paese si trova già con diverse norme che vanno a regolamentare il rapporto tra lavoro e tecnologia, andando a fornire protezione da eventuali minacce. Alcune di queste leggi derivano dall'adozione nazionale di regolamenti e direttive del diritto comunitario, ma la fonte prioritaria, sia perchè la più importante sia perchè la prima cronologicamente, è la legge n.300 del 1970, meglio nota come Statuto dei Lavoratori. Inutile dire che un testo - che per quanto tenuto aggiornato - sia stato scritto oltre 50 anni fa non può essere l'unico riferimento normativo necessario ad analizzare una materia come questa, ma la natura estensiva e di indirizzamento dello Statuto dei Lavoratori lo rende il punto di partenza obbligato per un'analisi di questo tema. All'interno dell'articolo 4 si trova la normativa in materia di strumenti di sorveglianza a distanza dei lavoratori. La spinta avanguardista del legislatore dimostra che non è meramente formale il passaggio su questa legge o frutto di un puro interesse accademico; invece, si tratta proprio di comprendere uno dei mattoni fondativi della materia giuslavorista e del suo incontro con il diritto alla privacy dei lavoratori in Italia con le conseguenti interazioni.

L'articolo 4 dello Statuto dei Lavoratori regola appunto la materia della sorveglianza a distanza dei lavoratori. La legge sancisce che gli strumenti da cui deriva questa pratica, specificando che non sono solo quelli audiovisivi, "possono essere impiegati esclusivamente per esigenze organizzative e produttive, per la sicurezza del lavoro e per la tutela del patrimonio aziendale". Questo vuol dire che all'interno del nostro ordinamento è già presente un limite per l'introduzione di nuove tecnologie nelle aziende, e che questo limite si basa prima di tutto sul fine dell'implementazione. **In altre parole, un datore di lavoro non può adottare una nuova tecnologia semplicemente per sperimentarla o per attrarre nuovi investitori** - come può essere il caso della ricerca nelle Intelligenze Artificiali - **ma deve prima verificare che questo non vada a ledere i diritti dei lavoratori, incluso quello alla privacy, o che il rischio sia accettabile dalla legge.** L'articolo prosegue esplicitando anche la necessità di un accordo con la rappresentanza sindacale, o in alternativa, in caso non sia materialmente possibile, con la sede

territoriale dell'Ispettorato Nazionale del Lavoro. Questo serve a rendere concretamente possibile il bilanciamento tra gli interessi dei lavoratori e del datore, che come vedremo più avanti è uno dei principi cardine del nostro ordinamento giuslavorista.

Nel 2019 questo articolo è stato emendato con il Jobs Act, andando ad esentare da questi limiti “gli strumenti di lavoro.” La definizione di questi strumenti è stata successivamente fornita dall'Ispettorato Nazionale del Lavoro e confermata dal Garante della Privacy, ed è la seguente: “tutti gli apparecchi, dispositivi, apparati e congegni che costituiscono il mezzo indispensabile al lavoratore per adempiere la prestazione lavorativa dedotta in contratto, e che per tale finalità siano stati posti in uso e messi a sua disposizione ... ovvero direttamente preordinati all'esecuzione della prestazione lavorativa ⁴”. In poche parole, questo emendamento è servito a superare il generale divieto degli strumenti tecnologici che potrebbero avere teoricamente ricadute di controllo - al giorno d'oggi questi strumenti sono indispensabili, pensiamo al GPS di un corriere - andando però a mantenere il principio della tutela presente nell'articolo 4.

Questa norma è stata scritta tenendo a mente la possibilità che il datore di lavoro introducendo nuovi strumenti tecnologici con l'obiettivo di migliorare la produttività aziendale corre il rischio di ledere i diritti e le tutele dei dipendenti. Il legislatore, andando a definire le lecite ragioni per questi sistemi di controllo, introduce un approccio fondamentale anche per quanto riguarda la materia di privacy: il principio della limitazione delle finalità ⁵. Un approccio del tutto paragonabile lo troviamo, infatti, anche all'interno del Regolamento generale sulla protezione dei dati, ovvero il regolamento europeo 2016/679 (d'ora in avanti GDPR). Nell'articolo 6 comma 1 del GDPR vengono delineate delle finalità idonee al trattamento dei dati; tra questi, nel caso dei lavoratori dipendenti sia pubblici sia privati, i più rilevanti sono: lettera b, “l'esecuzione di un contratto di cui l'interessato è parte ⁶”; lettera c, “il trattamento è necessario per adempiere un obbligo legale al quale è

⁴ Falco, W. (2019) “Il nuovo art. 4 St. lav.: tra strumenti di lavoro e privacy”

⁵ Iaselli M. (2023) “Il trattamento dei dati del dipendente nel rapporto di lavoro: principi e cautele”

⁶ Art. 6 GDPR - Liceità del trattamento, consultabile su *Altalex.com* <https://tinyurl.com/7x3rnwvt>

soggetto il titolare del trattamento ⁷”; e lettera f, “il trattamento è necessario per il perseguimento del legittimo interesse del titolare del trattamento o di terzi, a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell’interessato che richiedono la protezione dei dati personali ⁸”.

La base del principio di limitazione delle finalità nei confronti delle aziende è da trovarsi già nella Costituzione ⁹, che sancisce in modo chiaro all’articolo 41 che l’iniziativa economica privata è libera ma che vada anche equilibrata con l’utilità sociale e gli altri diritti individuali. Non ci troviamo, quindi, in un contesto di libertà economica pura ma, al contrario, in uno dove vada ricercato il difficile equilibrio esistente tra la protezione dei diritti dei lavoratori e le legittime esigenze aziendali. Questo è fondamentale da tenere a mente perché ci fornisce lo strumento logico-giuridico di partenza per andare a normare questa materia; il fine del nostro ordinamento è comunque quello di tutelare i diritti dei lavoratori, e tra questi possiamo inserire il diritto alla privacy. Per questo il nostro ordinamento è arrivato alla conclusione di normare la materia seguendo il principio regolatore di mantenere il trattamento dei dati al minimo, a maggior ragione se si tratta di dati sensibili ¹⁰.

Questa impostazione è confermata dal Garante Protezione dei Dati Personali (GPDP) che nelle sue linee guida specifica che “Il trattamento di dati personali riferibili a singoli lavoratori, anche sensibili, è lecito, se finalizzato ad assolvere obblighi derivanti dal contratto individuale (ad esempio, per verificare l’esatto adempimento della prestazione o commisurare l’importo della retribuzione, anche per lavoro straordinario, o dei premi da corrispondere, per quantificare le ferie e i permessi, per appurare la sussistenza di una causa legittima di assenza). Alcuni scopi sono altresì previsti dalla contrattazione collettiva per la determinazione di circostanze relative al rapporto di lavoro individuale ... o, ancora, dalla

⁷ Ibid.

⁸ Ibid.

⁹ Roma, G. et alii, (2023) “Tra GDPR e Statuto dei lavoratori: i profili di privacy del lavoratore sotto la lente del Garante”

¹⁰ Iaselli, op.cit.

legge.¹¹ Anche il GPDP segue il principio di limitazione delle finalità e soprattutto del ruolo ricoperto dal dialogo sindacale, che nel nostro ordinamento è sempre trattato come punto non facoltativo delle procedure di tutela dei dati dei lavoratori. Questo ragionamento ci porta a discutere degli obblighi informativi.

1.2 Obblighi informativi per il datore di lavoro

L'istituzione degli obblighi informativi è uno tra gli strumenti principali tra quelli che il nostro ordinamento fornisce ai lavoratori per garantire una trasparenza anche nel contesto aziendale. Questa materia, disciplinata dal GPDP, risulta centrale per diversi motivi. Prima di tutto, all'interno dell'ordinamento europeo in materia di trattamento dei dati quello dell'informativa è diventato un vero e proprio standard, applicato dal GDPR in diversi contesti che riguardano i dati sensibili. Inoltre, l'inserimento di comunicazioni verso i singoli coinvolti e dai portatori di interessi diffusi, avvia un processo di inserimento della tutela già nella fase di costruzione delle procedure che costituiscono l'attività ordinaria di un'azienda. Questo è il cosiddetto principio di *security by default*, ovvero l'idea che la sicurezza non sia semplicemente una pratica corretta ma che vada utilizzata come principio-costante di tutte le procedure di trattamento dei dati. Un principio che oggi cerca di avvolgere tutto il mondo della cybersecurity, come vedremo più avanti nella tesi.

Il diritto del lavoro italiano, come quello comunitario, non è estraneo agli obblighi informativi. Questi vengono già previsti da diverse norme, e si applicano ovviamente anche alla gestione dei dati dei lavoratori. Come già spiegato, nell'articolo 4 dello Statuto dei lavoratori troviamo menzionato l'obbligo di accordo con le rappresentanze sindacali o con la sede territoriale dell'ispettorato del lavoro. Questo è paragonabile in tutto e per tutto ad un obbligo informativo - anzi, è uno strumento ancora più avanzato andando a prevedere non solo una comunicazio-

¹¹ Garante per la Protezione dei Dati Personali (GPDP). Linee guida in materia di trattamento di dati personali di lavoratori per finalità di gestione del rapporto di lavoro alle dipendenze di datori di lavoro privati. Roma: deliberazione n. 53, 23 novembre 2006.

ne unilaterale da parte dal datore, ma l'esplicita menzione di un'intesa specifica anche la possibilità di azione dalla controparte.

Ma ancora di più dell'articolo 4, la vera norma di riferimento per quanto riguarda gli obblighi informativi del datore di lavoro è da ritrovarsi nel D.lgs. 152/1997. Si tratta di un decreto di attuazione di una direttiva comunitaria, la numero 533 del 1991, relativa agli obblighi di informazione sulle condizioni applicabili al contratto o al rapporto di lavoro che hanno come soggetto passivo i lavoratori. L'obiettivo del legislatore europeo era quello di armonizzare la materia a livello europeo, adottando una soluzione che potesse ridurre asimmetria informativa tra lavoratore e datore. La direttiva 91/533, basandosi sull'ordinamento del Regno Unito, aspirava ad un sistema in cui i lavoratori non sono all'oscuro di eventuali modifiche o di rischi alla loro sicurezza e alla loro salute.

Questa norma comunitaria è stata oggetto di un iter di riforma all'interno dell'Unione Europea stessa quando ci si è trovati a dover fronteggiare l'emergere dell'economia digitale, dell'informatizzazione e di nuove condizioni di lavoro. Il processo ha raggiunto una concretezza rilevante nel 2017 e si è concluso (per ora) nel 2019 con la direttiva 1152. In Italia è stata recepita nel 2022 con un decreto attuativo noto come Decreto Trasparenza, che è andato tra le altre cose a riscrivere l'articolo 1 del D.lgs. 152/1997 e ad arricchirlo di un articolo 1-bis dedicato esclusivamente proprio ai sistemi di decisione automatizzati. La riforma si concentra anche sull'inserimento all'interno della normativa già esistente, più di un riferimento esplicito a queste tecnologie in cui rientrano anche quelle basati sulle IA. L'articolo 1-bis fornisce un preciso profilo per gli obblighi di comunicazione verso i lavoratori di quei casi in cui "il datore di lavoro o il committente, pubblico o privato, utilizzi sistemi decisionali o di monitoraggio automatizzati" che devono essere informati "in modo chiaro, trasparente, completo e facilmente accessibile a distanza e per via elettronica, anche tramite portali online esistenti" utilizzando "i mezzi più appropriati". Quest'ultimo passaggio ci riporta di nuovo davanti alla questione di come il nostro ordinamento oggi non si accontenti semplicemente di avere procedure di sicurezza e/o trasparenza, ma richiede anche lo sforzo di curarle nel dettaglio calandole nella realtà della singola azienda o del singolo luogo di lavoro. In particolare, la normativa sancisce il diritto all'informazione - e

alla spiegazione - delle “informazioni significative”; ovvero delle motivazioni, delle responsabilità, dei dati, dell'equità, della sicurezza e dell'impatto.

Un aspetto distintivo dell'adozione italiana della direttiva europea riguarda il ruolo svolto dalle rappresentanze sindacali. Nel ordinamento giuslavorista del nostro paese i sindacati non sono soltanto considerati come un aggregato di lavoratori individuali - quindi già informati singolarmente - ma vengono come reputati un vero e proprio soggetto passivo separato. Questo perché qui il sindacato è uno strumento essenziale di tutela collettiva, al quale devono essere garantiti specifici obblighi di informazione e consultazione, indipendentemente dalla sua presenza all'interno della singola realtà aziendale. In assenza di rappresentanze sindacali dirette, la normativa prevede che la comunicazione avvenga nei confronti delle organizzazioni comparativamente più rappresentative a livello territoriale, assicurando così la protezione dei lavoratori e il rispetto del principio di partecipazione sindacale nei processi decisionali di rilievo¹².

I contenuti specifici delle informative sono normati dal GDPR, che ci fornisce una descrizione dettagliata. Secondo l'articolo 13 comma 1, queste informazioni devono essere fornite al momento di raccoglimento dei dati, che in alcuni casi può coincidere con la firma del contratto¹³. Le informazioni inerenti al materia giuslavorista si trovano sotto le lettere A, B, C e E; queste riguardano: A) l'identità e i dati di contatto del Titolare del trattamento e, ove applicabile, del suo rappresentante; B) i dati di contatto del Responsabile della protezione dei dati, ove applicabile; C) le finalità del trattamento cui sono destinati i dati personali nonché la base giuridica del trattamento; E) gli eventuali destinatari o le eventuali categorie di destinatari dei dati personali. All'interno del secondo comma dello stesso articolo 13, che specifica ulteriori informazioni da fornire all'interessato, sono rilevanti le lettere: A) il periodo di conservazione dei dati personali oppure, se non è possibile, i criteri utilizzati per determinare tale periodo; D) il diritto di proporre reclamo a un'autorità di controllo; E) se la comunicazione di dati personali è un obbligo le-

¹² Carinci, M. T., Giudici, S., e Perri, P. (2023). Obblighi di informazione e sistemi decisionali e di monitoraggio automatizzati (art. 1-bis “Decreto Trasparenza”): quali forme di controllo per i poteri datoriali algoritmici? *Labor Il Lavoro Nel Diritto*, 1/23.

¹³ Consultato su Altalex.com il 1 febbraio 2025, <https://tinyurl.com/yxwady8t>.

gale o contrattuale oppure un requisito necessario per la conclusione di un contratto, e se l'interessato ha l'obbligo di fornire i dati personali nonché le possibili conseguenze della mancata comunicazione di tali dati; F) l'esistenza di un processo decisionale automatizzato. Quest'ultimo punto è, senza ombra di dubbio, fondamentale per questa dissertazione.

1.3 Quadro complessivo e l'introduzione dell'IA ACT

Il quadro finora delineato ci serve a calare l'introduzione del regolamento europeo sull'intelligenza artificiale nel nostro ordinamento. L'interazione tra GDPR e Statuto dei Lavoratori configura già un'impostazione molto solida per la tutela dei lavoratori¹⁴. Ai lavoratori deve essere garantita una corretta valutazione del rischio volta a giustificare l'adozione di tecnologie che possono andare a costituire una minaccia ai loro diritti, incluso quello alla privacy. Inoltre, questa attenzione non solo deve essere dimostrata alle autorità competenti ma anche ai lavoratori con gli strumenti più opportuni, incluso il sindacato.

La portata principale dell'IA Act è quella di introdurre dei nuovi controlli che andremo ad analizzare nel prossimo capitolo. Prima, però, è giusto dedicare un momento a spiegare che questo regolamento non è affatto una rivoluzione o una modifica radicale dell'impostazione che abbiamo analizzato finora. Questo non per immobilismo del legislatore ma perché, semplicemente, non era necessario. Negli ultimi anni l'ordinamento europeo si era già attrezzato per gestire l'impatto dei processi automatizzati e, in ultima analisi, l'applicazione di queste tecnologie all'interno delle aziende non ha richiesto alterazioni fondamentali.

Le interazioni che l'ultimo regolamento ha con quanto disciplinato dal GDPR si può riassumere in tre scenari: duplicazione, integrazione e frizione¹⁵. Nella dupli-

¹⁴ Roma, G. et alii, op.cit.

¹⁵ Cappai M. (2024) "Intelligenza artificiale e protezione dei dati personali nel d.d.l. n. 1146: quale gover-

cazione, o sovrapposizione, rientrano tutti quei casi in cui il nuovo regolamento va sostanzialmente a confermare quanto sancito dal GDPR. Un esempio di questo caso è la normativa in caso di *data breach*, per cui viene previsto l'obbligo di comunicazione tempestiva all'autorità garante nell'ordinamento nazionale. Rientrano nel caso dell'integrazione quelle normative che vanno ad allargare i limiti imposti a chi adopera le tecnologie basate sull'intelligenza artificiale, facendo emergere i nuovi principi del processo normativo dietro l'IA Act e i nuovi sviluppi tecnici. Un esempio di questo caso è l'implementazione, affianco alla Valutazione d'Impatto sui Dati Personali (DPIA) dell'articolo 35 del GDPR, di una Valutazione d'Impatto sui Diritti Fondamentali (FRIA) per i casi considerati ad alto rischio, come le applicazioni di gestione aziendale ¹⁶. Un altro esempio di integrazione che vale la pena menzionare è l'inserimento della definizione dei “dati basati sulla biometria” che si affiancano ai “dati biometrici” del GDPR ¹⁷; questi nuovi dati sono quelli che servirebbero ad addestrare le IA, tra le varie cose al riconoscimento degli stati d'animo. Per ultima, la frizione consiste nell'estensione della base legale per l'esenzione, ovvero che vanno ad ampliare lo spettro delle deroghe previste dal GDPR ¹⁸. Questi casi sono i meno numerosi, e vanno sostanzialmente a tutelare la competitività dello sviluppo di IA all'interno del mercato unico europeo, un bilanciamento che col passare del tempo fa sempre più pressione sul legislatore. Un esempio si trova all'articolo 59 del regolamento che legittima il trattamento dei dati personali per lo sviluppo di sperimentazione normativa delle IA in nome dell'interesse pubblico. Interessante notare come anche in questo caso emerge una giustificazione in linea col principio di limitazione delle finalità.

nance nazionale?”, Federalismi.it, 18 dicembre 2024.

¹⁶ Roma, G. et alii, op.cit.

¹⁷ Tebano L. (2023) “Poteri datoriali e dati biometrici nel contesto dell'AI Act”, Federalismi.it, 18 ottobre 2023.

¹⁸ Ibid

CAPITOLO 2

**CONTROLLI E
CERTIFICAZIONI IN
UNIONE EUROPEA**

2.0 Premessa

L'intelligenza artificiale è senza alcun dubbio uno strumento dal potenziale rivoluzionario. Non serve sottolinearlo di nuovo¹⁹ ma la situazione attuale richiede di risolvere il problema dell'inserimento di questa tecnologia all'interno del mercato europeo e del suo ecosistema fatto di aziende nazionali, internazionali, pubbliche amministrazioni e normative. Il nostro ordinamento giuridico è preparato con un complesso sistema di principi e normative che servono proprio a risolvere in modo preciso il bilanciamento dei vari interessi. Tuttavia, se questo fosse sufficiente ogni problema quotidiano si potrebbe risolvere semplicemente con l'emanazione di una legge dopo un adeguato dibattito parlamentare. Al contrario, il mondo reale ha delle necessità concrete differenti che esulano dai principi legali e dagli strumenti normativi, che restano comunque il fondamento di tutto il sistema. Il passo successivo è comprendere quali problemi sono emersi finora e come si è tentato di risolverli finora. L'intelligenza artificiale rappresenta una delle più rilevanti innovazioni tecnologiche dell'era contemporanea, con un potenziale di trasformazione profonda nei settori economici, pubblici e sociali.

Tuttavia, uno dei principali ostacoli alla sua adozione su larga scala è costituito dalla diffusa mancanza di fiducia nei processi decisionali automatizzati. Questo *'problema zero'* è dovuto a diversi fattori, tra cui la percezione di opacità degli algoritmi, il rischio di bias nei modelli di IA, la difficoltà di interpretare le decisioni generate da sistemi complessi e la preoccupazione per il loro impatto etico e sociale. Anche la "Strategia Italiana per l'Intelligenza Artificiale 2024-2026"²⁰ riconosce questa problematica come centrale e propone un approccio sistemico per affrontarla, promuovendo lo sviluppo di soluzioni trasparenti, affidabili e conformi ai principi etici.

Costruire un clima di fiducia nei confronti di questa tecnologia è la partita fon-

¹⁹ Cfr. Introduzione di questa tesi

²⁰ Agenzia per l'Italia Digitale (AGID). Strategia italiana per l'intelligenza artificiale 2024-2026. Consultato online il 14 febbraio 2025. https://www.agid.gov.it/sites/agid/files/2024-07/Strategia_italiana_per_l_Intelligenza_artificiale_2024-2026.pdf

damentale per l'Unione Europea e per l'Italia, che ovviamente è completamente calata all'interno del sistema comunitario e del mercato unico e quindi non può immaginare di poter trovare una soluzione in isolamento. Per questo negli ultimi anni si sono andati a costituire una serie di strumenti che vadano a risolvere il 'problema zero' insieme a tutti gli altri problemi che sono emersi attorno all'IA. Anche all'interno dello stesso AI ACT troviamo affermazioni di principio che mirano allo sviluppo di un'intelligenza artificiale "etica ed affidabile ²¹".

L'approccio che si rivela essere comprensivo dei vari problemi in gioco è quello della *cybersecurity*, ovvero vedere l'implementazione di questa tecnologia attraverso la lente del *risk-management*. Questo approccio non solo permette di far emergere in modo non paralizzante le varie minacce, ma contribuisce alla risoluzione del 'problema zero'. Non stupisce, in effetti, che in Italia questo processo si basi sulla trazione delle due agenzie governative di questo settore, ovvero l'Agenzia per l'Italia Digitale (AGID) e l'Agenzia della Cybersicurezza Nazionale (ACN). Nonostante questa sia scelta sia al centro di un dibattito, che vedremo più avanti in questa dissertazione, in realtà questa scelta è in linea con altri numerosi paesi membri ²².

Per arrivare a comprendere i meccanismi di controllo dell'ultimo regolamento europeo sull'intelligenza artificiale, è fondamentale iniziare delineando i principi di *cybersecurity* su cui poggia il quadro europeo. La governance dell'IA deve necessariamente integrarsi con un quadro di cybersicurezza perché la protezione dei dati, la resilienza dei sistemi e la minimizzazione delle minacce e delle vulnerabilità costituiscono la base di un ecosistema digitale affidabile e sicuro.

Questo sistema è costruito a partire da criteri di gestione del rischio rigorosi comprendenti di valutazioni ex-ante e obblighi specifici che devono essere soddisfatti sia da sviluppatori sia dagli utenti, che nel caso del diritto del lavoro sono l'azienda o la pubblica amministrazione che implementano i sistemi di *algorithmic mana-*

²¹ Tebano L. (2023) "Poteri datoriali e dati biometrici nel contesto dell'AI Act", Federalismi.it, 18 ottobre 2023.

²² Cappai M. (2024) "Intelligenza artificiale e protezione dei dati personali nel d.d.l. n. 1146: quale governance nazionale?", Federalismi.it, 18 dicembre 2024.

gement. L'integrazione di tali misure di controllo mira a prevenire situazioni che potrebbero causare abusi o malfunzionamenti di sistemi che potrebbero compromettere la sicurezza dei lavoratori, oltre a quella delle infrastrutture critiche.

In quest'ottica, il regolamento sull'IA si inserisce in un più ampio processo di armonizzazione normativa, in cui la *cybersecurity* rappresenta non solo un aspetto tecnico, ma un vero e proprio principio fondamentale per assicurare lo sviluppo di un'intelligenza artificiale affidabile, resiliente e conforme ai valori essenziali dell'Unione Europea.

2.1 I principi della cybersecurity nella regolamentazione europea

La *cybersecurity* non è semplicemente un insieme di *best practices* (pratiche migliori o consolidate) mirate a combattere gli hacker, come magari può emergere dalla sua rappresentazione in film e serie TV. La *cybersecurity* è invece un paradigma culturale che mette insieme “metodologie e tecnologie atte a garantire la confidenzialità, l'integrità e accessibilità delle informazioni ²³”. Per questo è possibile ritrovare dei suoi principi anche all'interno dei regolamenti europei sulla Privacy e, in particolar modo, sull'intelligenza artificiale. Questo approccio però ha una sua storia oramai decennale, che non c'è lo spazio per attraversare in questa dissertazione; quello che ci interessa è definire questo approccio come la tutela di sei caratteristiche, note come Esade Parkeriana ²⁴, che sono: confidenzialità, integrità, accessibilità, autenticità, utilità e possesso (o controllo). Queste sei caratteristiche sono quelle che durante l'evoluzione della tecnologia informatica si sono rese necessarie da tutelare e valutare. I *data breach* possono essere definiti anche come la corruzione di questi valori.

Al contrario di quanto si possa pensare, non ci si può approcciare pensando di

²³ Limone, E. varie dispense riportate in bibliografia.

²⁴ Ibid.

portare il rischio allo zero. Invece, un approccio basato sulla sicurezza mira a quantificare il rischio. Questo permette di valutare l'efficacia delle misure preventive e anche di misurare un altro parametro di un'organizzazione: la resilienza. La resilienza è un termine che deriva dalla scienza dei materiali e serve a descrivere la capacità di un materiale di assorbire l'impatto di una forza senza rompersi; questo concetto applicato alla *cybersecurity* si traduce nella capacità del sistema di continuare a funzionare nonostante attacchi, minacce o altre criticità che si presenteranno²⁵. È fondamentale partire dal concetto di resilienza perché ci permette di introdurre uno dei principi che emergono da questo approccio - e che appunto ritroviamo anche in quello dell'Unione Europea - in cui le procedure e gli standard richiesti sono concreti e concretamente definibili. Senza di questo, ci si dovrebbe istintivamente porre l'obiettivo di azzerare, e non minimizzare, la possibilità di incidenti. Un obiettivo del genere è impossibile nella vita vera e porterebbe al primo episodio a frantumare la fiducia nella procedura, andando quindi ad amplificare il *'problema zero'* dell'implementazione dell'IA.

Questo principio della cultura della *cybersecurity* è riconoscibile all'interno dell'ordinamento comunitario, dove rappresenta un vero e proprio punto di partenza per la protezione delle infrastrutture digitali e la tutela dei diritti fondamentali. L'Unione Europea ha adottato un approccio normativo basato sulla valutazione e gestione del rischio, noto come *risk-based approach*, che costituisce il primo passo dell'AI Act e dell'iter normativo dietro a questo regolamento. Questo modello prevede che l'intensità dei controlli e degli obblighi di conformità sia proporzionata al livello di rischio che un sistema di IA può comportare per la sicurezza, la privacy e i diritti dei cittadini, a partire dalla finalità per cui è adottata e dal contesto in cui viene applicata. Di conseguenza, i sistemi di IA classificati come ad alto rischio sono soggetti a requisiti più stringenti in termini di trasparenza, affidabilità e monitoraggio continuo. Tale approccio si allinea alla cultura della *cybersecurity* già consolidata nel diritto europeo, promuovendo una gestione pro-attiva delle minacce informatiche e garantendo un equilibrio tra innovazione tecnologica e protezione degli utenti.

²⁵ Ibid

Possiamo verificare la serietà con cui il regolatore europeo prende questo approccio andando a sottolineare alcuni dettagli rivelatori. Sicuramente il primo che possiamo citare è l'attenzione data a mantenere aggiornate le classificazioni del rischio, che vanno riviste tramite una relazione almeno annuale. Anche se al momento questo obbligo tocca solo le tecnologie che riguardano i dati biometrici e i dati “basati sulla biometria ²⁶”, che risultano l'area più controversa e sensibile dello sviluppo di queste tecnologie, è chiaro che l'approccio non è quello di una classificazione *proforma* con il solo obiettivo di organizzare diversi livelli di restrizioni; invece, l'approccio *risk-based* è uno strumento per dissipare possibili dubbi e deve essere soggetto a revisioni affinché non perda di efficacia ²⁷.

Un altro principio della *cybersecurity* che possiamo ritrovare come principio normativo dell'IA nel mercato europeo, connesso sempre alla mitigazione del rischio, è invece quello di *risk-assessment* e *risk-prevention*. Cioè, dopo aver accuratamente valutato il livello di rischio e di attenzione - avendo messo quindi il concetto di rischio al centro della regolamentazione - il passo successivo è quello di analizzare concretamente quali sono le possibili minacce e quali sono le procedure da implementare per tenerli sotto controllo. Concretamente, ciò si traduce nell'obbligo della costruzione di un Documento di Valutazione dei Rischi (DVR) che a sua volta rientra nelle definizioni presenti nell'AI Act di Valutazione d'Impatto sui Dati Personali (DPIA) e Valutazione d'Impatto sui Diritti Fondamentali (FRIA) ²⁸.

Lo strumento della DPIA era già presente nel Regolamento generale sulla protezione dei dati (GDPR), che rimane la principale fonte normativa a riguardo e che possiamo andare a citare per comprendere come funziona questo strumento ²⁹. La valutazione d'impatto rappresenta un obbligo per il datore di lavoro nei casi

²⁶ Per la differenza tra questi dati cfr. il paragrafo 1.3 della tesi

²⁷ Tebano, L. Op. Cit.

²⁸ Giaccaglia, M. (2024). “La gestione algoritmica dell'impresa tra tutele dei lavoratori e prospettive partecipative (sul modello della sicurezza sul lavoro?)”. *Diritto della sicurezza sul lavoro*, (2), 478-502.

²⁹ D'Arcangelo, L. (2024). “Data protection e sicurezza sul lavoro: un documento di valutazione dei rischi (DVR) anche per la privacy?”. *Diritto della sicurezza sul lavoro*, (1), 48-63.

previsti dall'articolo 35, paragrafo 3³⁰. In particolare, essa è necessaria quando il trattamento dei dati avviene mediante modalità automatizzate (lett. a), quando riguarda categorie particolari di dati, quali quelli sensibili o relativi a condanne penali e reati (lett. b), oppure quando prevede un sistema di videosorveglianza sistematica che coinvolge spazi accessibili al pubblico (lett. c). Al paragrafo 7 troviamo invece i contenuti minimi della DPIA, che sono:

- a. una descrizione sistematica dei trattamenti previsti e delle finalità del trattamento, compreso, ove applicabile, l'interesse legittimo perseguito dal titolare del trattamento;
- b. una valutazione della necessità e proporzionalità dei trattamenti in relazione alle finalità;
- c. una valutazione dei rischi per i diritti e le libertà degli interessati di cui al paragrafo 1;
- d. le misure previste per affrontare i rischi, includendo le garanzie, le misure di sicurezza e i meccanismi per garantire la protezione dei dati personali e dimostrare la conformità al presente regolamento, tenuto conto dei diritti e degli interessi legittimi degli interessati e delle altre persone in questione.

Va specificato che questi sono requisiti essenziali, ma che non vanno necessariamente ad esaurire lo scopo della DPIA, e in casi particolari potrebbe servire anche arricchirla con altre informazioni.

Il Garante per la protezione dei dati personali, in una nota ufficiale pubblicata sul proprio portale, sottolinea come la DPIA non deve andare ad essere considerato esclusivamente un adempimento imposto dalla legge ma invece è da prendersi come una pratica altamente consigliata per una gestione consapevole dei rischi connessi al trattamento dei dati personali³¹. Le linee guida, già sottoposte a consultazione pubblica, ribadiscono che la valutazione d'impatto costituisce

³⁰ Testo del GDPR consultabile dal sito del Garante Protezione dei Dati Personali a questo link <https://tinyurl.com/5ymhbpew>

³¹ Limone, E. varie dispense riportate in bibliografia.

una buona prassi indipendentemente dagli obblighi legali, in quanto fornisce al titolare del trattamento un'analisi strutturata e dettagliata dei potenziali rischi, consentendogli di adottare misure preventive adeguate per ridurre la probabilità di incidenti futuri. Attraverso un'accurata DPIA, infatti, il titolare può non solo garantire un livello più elevato di protezione per gli interessati, ma anche rafforzare la propria affidabilità e dimostrare il rispetto del principio di *privacy by design* e *by default*, sancito dal GDPR. Seguendo approccio - che rientra a pieno in una visione costruita sui principi della cybersicurezza - si capisce che il fine della DPIA è quella di formalizzare la consapevolezza dei rischi, creare un momento specifico per la definizione di strategie e politiche per il loro contrasto e assicurare la personalizzazione e l'aggiornamento periodico di queste procedure.

La scrittura di una DPIA non è un compito scontato, ma richiede una metodologia di lavoro specifica, che richiede imparzialità e allo stesso tempo una conoscenza adeguata del contesto in cui le attività si svolgono. Per questo il CNIL, l'autorità amministrativa indipendente francese incaricata di assicurare l'applicazione della legge sulla tutela dei dati personali, ha reso disponibile un programma *open source* che aiuta alla compilazione di una corretta DPIA e anche il GPDP italiano ha consigliato l'utilizzo di questo software.

Un ultimo principio quasi etico della *cybersecurity* che ritroviamo nell'approccio regolatorio del legislatore europeo è quello della trasparenza e tempestività delle segnalazioni di incidenti. La condivisione di informazioni sugli incidenti gravi viene delineata direttamente dalla sezione 2 del Capo IX del regolamento sull'intelligenza artificiale.

Questo aspetto non è affatto secondario, ma rappresenta un meccanismo essenziale sempre volto a risolvere il '*problema zero*' dell'affidabilità. Le segnalazioni concretamente non dovrebbero essere viste come un episodio da nascondere per tutelare l'immagine dell'azienda o dell'amministrazione pubblica; mentre una gestione scorretta di questi episodi può portare anche a danni irreparabili alla reputazione, il rispetto delle procedure prestabilite e una comunicazione adeguata possono contribuire a rafforzare la sicurezza (con una valutazione *ex post* dell'incidente) e anche alla sua proiezione esterna. Una pratica consigliata infatti è quella di provvedere anticipatamente a queste comunicazioni, mettendo

già in chiaro le informazioni che potrebbero essere compromesse, quali sono le procedure di *crisis-management* e di resilienza strutturale e quale linguaggio utilizzare verso gli *stakeholders* in questione, tra cui gli stessi lavoratori.

Evidentemente, quest'ultimo principio ha senso solo se calato all'interno dell'intero approccio di *cybersecurity*, e in generale possiamo dire a questo punto che l'immagine complessiva del regolamento europeo è quella proprio di indirizzare - principalmente le aziende - verso l'adozione di questo approccio non come singoli obblighi da rispettare, ma come paradigma culturale a tutto tondo.

2.2 I controlli e le autorità di vigilanza nel quadro post AI ACT

Se l'approccio incoraggiato dalle norme europee è quello della sicurezza come metodo, il mondo reale spesso non rispecchia quanto auspicato dal legislatore - europeo o nazionale che sia. Non stupisce che quindi l'ultimo regolamento sulle Intelligenze Artificiali preveda anche un sistema di controlli basato su autorità e responsabilità.

Questo perché al di là delle pratiche di prevenzione e valutazione del rischio, il problema di affidabilità degli algoritmi e delle tecnologie IA non è ancora risolto. Inoltre, non è un segreto che attorno a questo sviluppo tecnologico ci sia un interesse economico considerevole ed è quindi sensato preparare un sistema di controlli robusto, per assicurarsi che le norme di sicurezza e di etica continuino a essere applicate per tutto il ciclo di vita dell'IA ³².

Il sistema di responsabilità che esce dall'AI Act non è un sistema che ricade solo sui produttori di questi software, ma correttamente ricade su tutti gli *stakehol-*

³² Iaselli M. (2024) "Dalla verifica reale dei prodotti una difesa per i diritti fondamentali. I controlli successivi"

der coinvolti; questo include gli utenti finali, anche noti come *deployer*³³, che la maggior parte delle volte sono le aziende o le pubbliche amministrazioni che acquistano questi servizi per gestire i dati dei loro dipendenti. Questo sistema è particolarmente critico per i sistemi di IA ad alto rischio, come l'utilizzo volto all'organizzazione dei lavoratori, dove il fallimento o malfunzionamento potrebbe avere conseguenze gravi³⁴.

2.2.1 Il capo IX dell'AI Act, le procedure di monitoraggio

Entrando nello specifico, il capo IX (Articoli da 72 a 94 dell'AI Act) è dedicato alle procedure di monitoraggio successive all'immissione nel mercato. Questa tesi si limita ad elencare gli articoli essenziali per dare un quadro di queste procedure, prima di discutere il caso italiano. Si rimanda all'analisi dell'avvocato e docente universitario Michele Iaselli per una dissertazione articolo per articolo di questo capo³⁵.

All'interno dell'articolo 76 viene specificata la necessità di test non solo all'interno di ambienti controllati, ma anche sul campo e calati nella realtà quotidiana. Questo è fondamentale perché ci fa comprendere l'inevitabilità sia di un sistema di controlli successivi all'immissione in mercato sia del coinvolgimento del *deployer*, che è senza dubbi la fonte migliore - se non l'unica - di informazioni sul lavoro quotidiano dei sistemi di IA. Gli obiettivi di questi controlli sono tre:

- a. misurare la resilienza e l'adattabilità dei sistemi di decisione automatica;

³³ “La nozione di «deployer» di cui al presente regolamento dovrebbe essere interpretata come qualsiasi persona fisica o giuridica, compresi un'autorità pubblica, un'agenzia o altro organismo, che utilizza un sistema di IA sotto la sua autorità, salvo nel caso in cui il sistema di IA sia utilizzato nel corso di un'attività personale non professionale. A seconda del tipo di sistema di IA, l'uso del sistema può interessare persone diverse dal deployer”, Reg.UE 2024/1689, considerando 13

³⁴ Iaselli M. (2024) “Monitoraggio post-vendita per un sistema più efficiente. I controlli successivi”

³⁵ Nella bibliografia sono riportati i diversi articoli contenuti nel quinto dossier del 2024 di *Guida al diritto* curato dal Sole24Ore.

- b. identificare possibili discrepanze con i dati forniti dai fornitori di questi software,
- c. raccogliere informazioni per affinare le politiche regolatorie in materia.

Nell'articolo 78 viene fatta emergere la necessità della confidenzialità nella gestione delle informazioni fornite dai *deployer* che emergono attraverso le procedure di controllo. Questo perché parlando di operatori economici, c'è il rischio che si possa temere della propria competitività con una conseguente perdita di trasparenza; un rischio che risulta amplificato trattandosi di una cooperazione internazionale all'interno del mercato unico europeo. Anche per questo problema è la *cybersecurity* ed il GDPR che mostrano la strada verso una soluzione: la "pseudo-anonimizzazione" è un metodo di riservatezza già utilizzato, che permette di gestire anche dati sensibili slegandoli dalle specificità identificative. Questo genere di approccio è proprio quello che l'articolo 78 richiama.

È l'articolo 79 che ci permette di costruire una procedura specifica per la gestione dei sistemi di IA, differenziando sostanzialmente due fasi. La prima riguarda esclusivamente i produttori, che devono sottoporre le loro intelligenze artificiali ad una valutazione del rischio per ottenere una classificazione (o *rating*) del livello di rischio. Questa è anche l'occasione per bloccare preventivamente quelle IA che non sono state costruite con le corrette procedure di minimizzazione del rischio, fatte apposta per evitare bias o discriminazioni sistematiche. La seconda fase riguarda invece i *deployer*; in caso di classificazione a basso rischio forniscono i dati per mantenere aggiornato il *rating* di rischio del prodotto che hanno acquistato e della sua implementazione, mentre nei casi di rischio medio o alto devono fornire questi dati per una sorveglianza specifica e per costruire la necessaria fiducia sull'utilizzo di questi sistemi.

Come specificato negli articoli successivi, i sistemi di monitoraggio e reporting non sono punti fissi ma processi continui che si basano sulla collaborazione tra fornitori, *deployer* e autorità di vigilanza, con l'obiettivo comune di risolvere il '*problema zero*' dell'IA e di condividere le pratiche migliori all'interno di un contesto competitivo. È evidente che i primi due attori non hanno un interesse completamente genuino nella minimizzazione del rischio, ed è per questo che la figu-

ra dell'autorità di vigilanza diventa così cruciale. Nell'articolo 77 viene specificato che loro non hanno solo il dovere di monitorare e valutare lo strumento tecnologico, ma anche di intervenire sulle politiche di prevenzione e mitigazione del rischio implementate. Lo strumento per farlo è l'accesso anche a dati e documenti durante indagini ed ispezioni specifiche. La premessa sulla collaborazione serve a specificare che questo compito non è volto a “pizzicare” e punire chi sceglie di adoperare queste tecnologie, quanto a rendere l'unione europea un polo di concentramento e distribuzione delle pratiche di sicurezza. Non a caso, l'articolo 84 prevede l'istituzione di “strutture di sostegno” che vadano a favorire questa collaborazione, come per esempio aiutando le start-up nella compilazione dei Documenti di Valutazione del Rischio, oltre che a dedicare risorse proprio nel testare la sicurezza delle IA.

Fuori dal capo IX dell'AI Act, all'interno dell'Articolo 8 viene imposto anche l'obbligo di una consultazione con i lavoratori e le loro rappresentanze e di fornire loro la DPIA finale. Un obbligo che ricade sempre sul *deployer*, che però secondo gli articoli 9 e 13 dell'AI Act deve ricevere dal fornitore tutte le informazioni necessarie ad adempiere all'obbligo³⁶. A dimostrazione che tutti questi processi non sono slegati dalla tutela dei lavoratori, ma anzi li riguardano in primo luogo.

2.2.2 Quali sono le autorità sull'IA in Italia?

Finora abbiamo parlato in modo generale di “autorità di vigilanza”, senza specificare quali queste siano. Finora abbiamo parlato in modo generale di “autorità di vigilanza”, senza specificare quali queste siano. Nel Capo VII del regolamento dedicato alla *governance*, a livello europeo l'Unione ha optato per l'istituzione di una commissione dedicata, incaricata di garantire l'attuazione e il rispetto delle normative in materia di intelligenza artificiale e protezione dei dati. Tale organismo funge da punto di riferimento per gli Stati membri, promuovendo un'in-

³⁶ Aimo, M. (2024). “Il management algoritmico nel lavoro mediante piattaforma digitale: osservazioni sulle prime regole di portata europea.”

interpretazione armonizzata delle disposizioni regolamentari e assicurando un coordinamento efficace tra le diverse giurisdizioni nazionali. A livello nazionale, invece, gli Stati hanno mantenuto un margine di autonomia nella definizione del proprio sistema di supervisione, con la facoltà di individuare a chi dare il compito di vigilanza per garantire il rispetto della normativa. La condizione essenziale imposta dal quadro normativo europeo è che tali autorità dispongano delle risorse economiche e umane necessarie per svolgere efficacemente il proprio ruolo, garantendo un monitoraggio costante, l'applicazione delle sanzioni previste e l'adozione di misure adeguate per prevenire e mitigare i rischi connessi all'uso delle nuove tecnologie.

Senza fornire una strutturazione ottimale, il regolatore europeo lascia tre opzioni possibili, tutte compatibili con il regolamento. La prima è quella di allargare i poteri del Garante della Protezione dei Dati Personali, la seconda è quella di allargare gli incarichi forniti ad altre agenzie governative già attivi sulle materie informatiche o digitali e la terza è quella di costruire degli enti o delle agenzie specifiche per la vigilanza delle Intelligenze Artificiali ³⁷.

La scelta dell'esecutivo italiano, adottata tramite il d.d.l 1146 del 20 maggio 2024, è stata quella di costruire un sistema a “trazione duale” tra l'AgID e l'ACN, lasciando ferme competenze, compiti e poteri del GPDP. Il primo ha il compito di promuovere l'innovazione e lo sviluppo dell'intelligenza artificiale, mentre il secondo è responsabile di identificare i profili della cybersicurezza e dell'attività di vigilanza. Il decreto prevede anche un comitato di coordinamento presso il consiglio dei ministri, in particolare assicurando la cooperazione con il Ministero della Difesa, il Ministero delle Imprese e del *Made in Italy* e con le altre autorità nazionali dell'unione. Sostanzialmente, l'impostazione presentata dal governo è quella di mantenere vicino a sé la *governance* dell'IA, rispetto a decentrarla allargando i poteri di un organo di indipendente come il GPDP. Una scelta che, vista la strategicità della materia, non stupisce sia quella più comune tra gli stati membri ³⁸.

³⁷ Cappai M. (2024) “Intelligenza artificiale e protezione dei dati personali nel d.d.l. n. 1146: quale governance nazionale?”, Federalismi.it, 18 dicembre 2024.

³⁸ Ibid.

Nonostante questa sia una scelta prevista dall'impostazione comunitaria, il Garante della Privacy italiano ha fatto sentire il suo dissenso con la decisione. Il GDPR ha portato la richiesta di essere integrato all'interno delle procedure di consultazione e vigilanza sia in ragione di semplificazione e di certezza del diritto, rimanendo comunque l'autorità in quanto alla gestione dei dati sensibili e delle procedure di decisione automatizzata, sia in ragione al fatto che la sua attività corrente le permette di essere un ente che ha già accumulato il *know-how* pratico e la *expertise* riguardo l'attività di vigilanza in questa materia. La scelta di non tenere esclusivamente in mano all'esecutivo il coordinamento dell'attività di vigilanza andrebbe a favorire anche il clima di collaborazione con le autorità degli stati membri, che resta un principio cardine dell'AI Act.

La ragione fondamentale dietro il ragionamento dell'esecutivo è che anche a livello europeo in realtà gli esecutivi vengono presi come punto di partenza della discussione per il bilanciamento strategico tra tutela dei dati e competitività di mercato, con l'istituzione all'articolo 65 del regolamento di un "consiglio europeo per l'intelligenza artificiale" composto da un rappresentante per ogni stato membro di emanazione ministeriale. Un argomento troppo spinoso e controverso per lasciarlo 'fuori controllo' e che dimostra come il '*problema zero*' della fiducia in questi sistemi abbia a volte anche delle emanazioni non scontate. È possibile che col tempo questa impostazione possa vedere delle modifiche, ma al momento è l'esecutivo l'attore centrale di queste procedure di controllo, mentre il GDPR viene relegato ad una voce da consultare in regime di coordinamento volontario quando richiesto dalle agenzie governative preposte.

2.3 Il modello delle certificazioni ISO e della direttiva NIS2

Chiudiamo questo quadro andando a guardare quelle che sono le certificazioni che le aziende o le pubbliche amministrazioni possono ottenere in materia di *data protection*. Queste certificazioni sono centrali perché pensate per essere

compatibili con i processi di controllo previsti dai regolamenti europei e soprattutto perché diventano uno strumento necessario alla costituzione di un clima di affidabilità con gli *stakeholder* esterni, come gli investitori o i clienti, e gli *stakeholder* interni, come i lavoratori.

Le certificazioni ISO sono rilasciate da agenzie accreditate alla verifica di standard europei. In realtà, non si limitano soltanto alla sicurezza informatica ma possono riguardare anche le norme anticorruzione (ISO 37001) o la sostenibilità ambientale (ISO 14001). Quella riguardo le procedure di trattamento delle informazioni è la ISO 27001, che ha visto un aggiornamento dei suoi requisiti nel 2021. La peculiarità di queste certificazioni è che sposano appieno l'approccio della *cybersecurity* che abbiamo presentato nel primo paragrafo di questo capitolo. Ovvero, non hanno semplicemente dei requisiti essenziali che vengono verificati meccanicamente, ma si basano su delle verifiche dettagliate che misurano in modo personalizzato l'approccio e le procedure delle singole aziende o pubbliche amministrazioni. Questo approccio si nota particolarmente nell'ISO 9001 dedicata ai controlli qualità, una materia che appunto è difficilmente standardizzabile se affrontata con un approccio "minimalista"³⁹. Infatti, possiamo prendere la struttura di questa ISO come lo standard di questo tipo di certificazione, con paralleli anche nella ISO sulla sicurezza dei dati, e che si sposa con i problemi posti dalle IA.

La certificazione dà grande rilievo al *risk management*, che abbiamo già ampiamente discusso, enfatizzando l'approccio "per processi", ovvero partendo dalla scomposizione delle attività in singoli processi. Non sono esenti da valutazione quei processi svolti materialmente da soggetti esterni, anzi necessitano un'attenzione particolare in quanto richiedono una valutazione della strategicità o meno di questa esternalizzazione. Il primo passo è proprio quello di identificare i problemi, le aspettative e i bisogni delle parti interessate, da anticipare per determinare i rischi - e le opportunità - da trattare nella costruzione di procedure e di *defaults*. Il passo successivo è l'identificazione delle figure di leadership, che nella ISO 9001 è il *System Quality Manager* a capo di un "*Sistema Gestione Qualità*" (SGQ), diverso

³⁹ Limone usa questo termine per indicare l'approccio delle certificazioni che controllano una serie di "mini" evitando di affrontare la maggiore complessità di certi processi, come per esempio la gestione delle IA.

da un rappresentante della direzione - esclusa dal testo del 2015 - ma che invece è preposta alla verifica continua di queste procedure attraverso quelle che vengono definite “informazioni documentate”. La costruzione sia di una leadership sia di una traccia di documenti è un cambio di paradigma di gestione essenziale. Prima di tutto assicura una continuità in caso di cambi nella direzione o nella gestione, visto che le informazioni essenziali e la loro evoluzione nel tempo lascia una traccia tangibile, ma soprattutto va a facilitare quella collaborazione con le autorità di vigilanza previste dalla legge. La struttura si chiude con un'enfasi sulle valutazioni delle prestazioni dell'organizzazione attraverso parametri e indicatori quantitativi e qualitativi, in grado di far emergere criticità e *best practices* da includere nelle future strategie. Lo scopo della ISO 27001 è quello di “specificare i requisiti per stabilire, implementare, mantenere e migliorare continuamente un sistema di sicurezza per la gestione dei dati ⁴⁰” e mostra una struttura fatta col calco della sorella ISO 9001 che abbiamo appena visto. La ISO 27001 richiede dopo l'identificazione degli *stakeholders* - di cui fanno sicuramente parte i lavoratori - delle misurazioni per cinque aspetti delle procedure: contesto, leadership, pianificazione, supporto (o meglio, risorse) e attività operative. Queste informazioni documentate devono essere formulate in modo da essere consistenti, misurabili quando praticabile, monitorabili, comunicabili in modo chiaro, in modo da definire concretamente responsabilità, compiti e risorse.

La ISO 27001, in particolare, richiede anche l'istituzione di procedure per la gestione di incidenti oltre alla semplice pianificazione e preparazione, come la valutazione di singoli episodi che possono far emergere nuove minacce o procedure per l'identificazione, la raccolta, l'acquisizione e la conservazione delle prove relative agli eventi di sicurezza. Un'altra peculiarità rispetto alla ISO9001 è il focus sull'implementazione di procedure di *disaster recovery*, ovvero la capacità del sistema di mitigare non solo il rischio di incidente ma anche gli effetti di eventuali fughe di dati o altri eventi disastrosi, partendo dal presupposto che sia impossibile prevedere tutti i possibili scenari.

Il modello delle ISO emerge già chiaramente come un sistema molto affidabile

⁴⁰ International Organization for Standardization, ISO 27005:2022

per certificare l'esistenza di un approccio sistematicamente organizzato e basato sulla valutazione e mitigazione del rischio, ma non è l'unico. Affianco a queste certificazioni abbiamo la direttiva europea NIS2, che nel 2022 è andata a sostituire la direttiva sulla sicurezza delle reti di informazione (Network Information Security, NIS). Come quella che l'ha preceduta, l'obiettivo di questa direttiva è quello di definire 10 principi di sicurezza che gli attori esposti alle reti e infrastrutture di informazioni devono rispettare. Il primo si basa sull'implementazione di un approccio della valutazione e mitigazione nel rischio ma se vediamo gli altri nove vediamo un'importante interazione con la ISO 27001, essi sono

1. L'implementazione di un approccio basato sulla valutazione e mitigazione del rischio, che è letteralmente lo standard di questo settore;
2. adozione di misure per garantire che anche i fornitori e le terze parti coinvolte rispettino gli standard di sicurezza;
3. obbligo di procedure di segnalazione dei dettagli essenziali di incidenti in 24 ore e di un rapporto dettagliato in 72 ore;
4. sviluppo di piani di continuità operativa;
5. effettuazione di test periodici e valutazioni ricorrenti delle vulnerabilità;
6. implementazione di controlli d'accesso rigorosi per sistemi ed infrastrutture critici;
7. formazione regolare del personale sulle best practices;
8. adozione di tecniche di crittografia avanzata e altre misure per la protezione dei dati sensibili, sia in transito sia a riposo;
9. promozione della condivisione delle informazioni su minacce e incidenti a livello nazionale ed europeo;
10. supervisione da parte delle autorità competenti con sanzioni severe per le organizzazioni che non rispettano i requisiti di sicurezza.

Possiamo vedere la direttiva NIS2 come una armonizzazione finale di tutti i principi del quadro regolatorio europeo che va a stringere per quelle aziende e quelle amministrazioni pubbliche essenziali e importanti, che sono inevitabilmente esposte a delle minacce da parte di attori malintenzionati o con interessi nel ledere la loro sicurezza. Questo è un approccio particolarmente efficace per i sistemi di intelligenza artificiale, che non solo rappresentano di per sé una possibile minaccia, ma si offrono come punto debole della corazza digitale europea. La direttiva NIS2 è un modello di regolamentazione più forte che però sposa a pieno l'approccio che si è adottato con le IA.

Il grande problema delle ISO e della NIS2, però, è che la prima è esclusivamente su base volontaria - anzi, deve essere letteralmente acquistata come certificazione - mentre la seconda diventa obbligatoria in base alla criticità e all'essenzialità di un determinato settore. Vista la criticità dell'implementazione di un'intelligenza artificiale e visto il riconoscimento che fa la stessa Unione Europea del pericolo rappresentato dalla gestione automatizzata dei dati personali, questi modelli rappresentano un'alternativa a cui guardare quando si parla di regolamentazione.

Conclusioni

Alla fine di questa analisi possiamo dare un quadro generale dei principi e delle modalità con cui l'Unione Europea ha regolamentato la gestione dei dati dei dipendenti. L'obiettivo generale dell'impalcatura regolatrice europea è quella dello sviluppo di un'intelligenza artificiale per il bene sociale (AI4SG) come vantaggio strategico sugli altri attori globali all'interno della competizione per lo sviluppo di nuovi modelli di IA. Questo modello si basa sul bilanciamento tra la tutela dei diritti dei cittadini - incluso quello alla privacy - e la necessità dell'utilizzo dei loro dati per lo sviluppo tecnologico. Dopo l'adozione dell'AI Act è chiaro che il regolatore europeo ha deciso di mettere chiari limiti all'utilizzo dei dati per permettere un certo grado di libertà all'interno di questi.

L'adozione di questo approccio all'interno dell'ordinamento giuslavorista italiano ha incontrato delle tutele già esistenti, sia dal punto di vista dei principi sia dal punto di vista degli strumenti normativi; in particolare, la Costituzione e lo Statuto dei lavoratori fanno emergere l'importanza del principio della limitazione delle finalità, che attivamente restringe l'iniziativa economica del datore di lavoro, mentre lo stesso Statuto e il GDPR hanno già ampiamente normato lo strumento degli obblighi informativi. Questo quadro giuridico è necessario a far emergere come le tutele presenti nelle direttive e nei regolamenti europei, rivolte genericamente ai cittadini, riguardano anche le aziende e, in particolare, ai lavoratori. Non è per niente secondario sottolineare che nel concreto gli attori che già applicano le intelligenze artificiali sono le aziende che sperimentano *l'algorithmic management*, cioè che usano intelligenze artificiali per analizzare i dati dei dipendenti e ottimizzare l'organizzazione del lavoro.

Materialmente, l'approccio europeo si sposa con diversi principi della *cybersecurity*, soprattutto basandosi sulla valutazione e mitigazione del rischio concreto e personalizzato per ogni applicazione, il cosiddetto *risk-based approach*. Ciò comporta diverse cose per gli attori economici che decidono di adottare queste tecnologie, al di là che essi siano aziende o pubbliche amministrazioni. Per prima

cosa si devono impegnare a fare dei controlli ex-ante, sotto forma di valutazioni d'impatto sui dati personali e su altri diritti fondamentali. Questi documenti non devono essere scritti come semplici liste di minimi raggiunti - o paradossalmente provare a dimostrare l'infallibilità delle proprie attività - ma devono essere svolte in dettaglio per anticipare quanti più possibili minacce. Di conseguenza, questo sistema comporta anche sottostare ad un regime di monitoraggio con le autorità competenti a livello nazionale ed europeo e prepararsi anche con delle specifiche politiche di *crisis-management*, che partono dal mantenere l'operatività anche in caso si verifichi un incidente fino al mantenere un rapporto collaborativo e comunicativo con il Garante della Protezione dei Dati Personali.

Oltre alle procedure di monitoraggio e di collaborazione reciproca tra organizzazioni e autorità, un elemento chiave della strategia europea diventa quello delle certificazioni. Per ultima, è stata la direttiva NIS2 ad introdurre degli standard di sicurezza per i nodi critici ed essenziali della rete di informazioni europea, ma ancora prima esisteva già il sistema di certificazione ISO. Questo tipo di certificazione, soprattutto quelle legate a questa materia come la ISO 27001, anche se volontaria si dimostra essere uno strumento indispensabile perché non vengono rilasciate a seguito della verifica di uno standard universale; paradossalmente, quello che rende efficace nella standardizzazione delle ISO è proprio la personalizzazione delle verifiche per cui quello che viene certificato è l'effettiva qualità - in questo caso della gestione dei dati dei propri dipendenti e di terzi coinvolti.

All'interno di questo quadro emerge una direzione ben marcata: sono richiesti degli standard di sicurezza per adoperare le IA nel mercato europeo. C'è da dire che sono comunque emersi dei punti di tensione all'interno del sistema regolatorio europeo. Prima di tutto, vista la natura cruciale di questa materia c'è un conflitto su quanta autonomia lasciare alle procedure di monitoraggio. Se da un lato più autonomia potrebbe portare ad una qualità di controllo più stringente, la scelta di affidare ad agenzie governative questo compito dimostra quantomeno la volontà degli esecutivi europei di lasciarsi qualche forma di influenza - probabilmente soprattutto quanto riguarda la competizione internazionale. Rientra nello stesso filone, il problema delle certificazioni ISO che rimangono un prodotto che deve essere acquistato tramite degli enti certificatori privati. Se questo permette

effettivamente di garantire un buon livello di controllo, dall'altro rende virtualmente impossibile estenderlo a tutte le aziende e le pubbliche amministrazioni che effettivamente andrebbero a beneficiare *dell'algorithmic management*. Allo stato attuale delle cose c'è invece anche un criterio di selezione economico, che però tiene comunque in considerazione i lavoratori escludendo chi non ha questo standard dalla possibilità di usare questa tecnologia.

Una chiave di lettura per futuri regolamenti può trovarsi in quello che abbiamo chiamato il *'problema zero'* dell'intelligenza artificiale: l'affidabilità. Questo punto di partenza ci permette di districare questi primi nodi, ed altri a seguire, scegliendo la soluzione che permette di creare un'clima con la necessaria fiducia per questi strumenti tecnologici. Non solo possiamo citare quindi dei controlli indipendenti, stringenti e magari finanziati attraverso strumenti pubblici - visto che le direttive europee già parlano di creare uffici dedicati a questi, basterebbe dargli le risorse necessarie a fare davvero bene questo lavoro - ma possiamo citare lo strumento (tutto italiano) della partecipazione dei lavoratori in questi processi. Il fatto che nel nostro ordinamento l'adozione di queste tecnologie richiede la consultazione delle organizzazioni sindacali e un accordo con quelle comparativamente più rappresentative è uno strumento cruciale nella battaglia per aumentare la fiducia nella tecnologia.

Questa tesi non mira ovviamente ad essere esaustiva dell'argomento, ma dopo aver dato un quadro generale di come le cose dovrebbero funzionare a seguito dell'implementazione dell'AI Act ci sono anche successive possibilità di studio. Prima di tutto servirebbe una verifica sperimentale di quante aziende e pubbliche amministrazioni hanno queste certificazioni e concretamente quali sono queste *best practices* che stanno emergendo. Probabilmente un sistema pubblico europeo andrebbe ad incoraggiare una certa sistematizzazione di questo processo, ma non essendo all'orizzonte servirebbe anche costruire un'immagine concreta dello stato attuale delle cose.

Un'altra prospettiva da approfondire è quanto si stia dimostrando efficace il coinvolgimento delle organizzazioni sindacali in questo processo. Si può dare per certo che non è sufficiente rendere obbligatoria la consultazione con i sindacati per costruire davvero questo clima di fiducia, ma serve lo sforzo ulteriore affinché i

lavoratori si sentano realmente protagonisti in questi processi. La base giuridica per questo si può ritrovare nel fatto che, come abbiamo ribadito diverse volte in questa tesi, i dipendenti di un'azienda non sono meri strumenti produttivi ma veri e propri portatori di interessi interni all'azienda; visto che in tutti i processi di valutazione citati in questa analisi gli *stakeholder* hanno sempre un ruolo rilevante, dovrebbe essere chiaro che un gruppo così centrale al funzionamento di un'azienda dovrebbero avere un altrettanto ruolo centrale in processi del genere.

Questa prospettiva avrebbe delle ricadute decisamente positive; riguardando decine di milioni di persone solo nel nostro paese - l'INPS nel 2022 ne contava 26,6 milioni - andrebbe attivamente a diffondere quanto meno la conoscenza che la sicurezza dei propri dati viene considerata nei processi di costruzione delle pratiche aziendali. Questo è già effettivamente negli obiettivi del legislatore europeo, il che dimostra che siamo sulla strada giusta; tuttavia, nel momento in cui si decide che la strategia europea per il mercato delle IA è quella di diventare il polo regolatore allora c'è bisogno di andare fino in fondo con questa prospettiva. Le basi tecniche e giuridiche ci sono, serve solo avere la determinazione necessaria.

Bibliografia

- Agenzia per la Cybersicurezza Nazionale (ACN). Determinazione del Direttore generale dell'Agenzia per la cybersicurezza nazionale. Roma, 26 novembre 2024.
- Agenzia per l'Italia Digitale (AGID). Strategia italiana per l'intelligenza artificiale 2024-2026. Consultato online il 14 febbraio 2025. https://www.agid.gov.it/sites/agid/files/2024-07/Strategia_italiana_per_l_Intelligenza_artificiale_2024-2026.pdf
- Aimo, M. (2024). "Il management algoritmico nel lavoro mediante piattaforma digitale: osservazioni sulle prime regole di portata europea." *Federalismi.it*, (25), 216-230.
- Cappai M. (2024) "Intelligenza artificiale e protezione dei dati personali nel d.d.l. n. 1146: quale governance nazionale?", *Federalismi.it*, 18 dicembre 2024.
- Carinci, M. T., Giudici, S., e Perri, P. (2023). "Obblighi di informazione e sistemi decisionali e di monitoraggio automatizzati (art. 1-bis "Decreto Trasparenza"): quali forme di controllo per i poteri datoriali algoritmici?" *Labor Il Lavoro Nel Diritto*, 1/23".
- D'Arcangelo, L. (2024). "Data protection e sicurezza sul lavoro: un documento di valutazione dei rischi (DVR) anche per la privacy?." *Diritto della sicurezza sul lavoro*, (1), 48-63.
- Falco, W. (2019). "Il nuovo art. 4 St. lav.: tra strumenti di lavoro e privacy", *Toffoletto De Luca Tamajo E Soci*, 15 ottobre 2019.
- Giaccaglia, M. (2024). "La gestione algoritmica dell'impresa tra tutele dei lavoratori e prospettive partecipative (sul modello della sicurezza sul lavoro?)". *Diritto della sicurezza sul lavoro*, (2), 478-502.

- Garante per la Protezione dei Dati Personali (GPDP). Linee guida in materia di trattamento di dati personali di lavoratori per finalità di gestione del rapporto di lavoro alle dipendenze di datori di lavoro privati. Roma: deliberazione n. 53, 23 novembre 2006. Consultato online il 23 gennaio 2025.
- Iaselli M. (2023) "Il trattamento dei dati del dipendente nel rapporto di lavoro: principi e cautele", *Agenda Digitale*, 18 maggio 2023. Consultato online il 23 gennaio 2025. <https://tinyurl.com/36xv73vk>
- Iaselli M. (2024) "Dalla verifica reale dei prodotti una difesa per i diritti fondamentali. I controlli successivi", *Guida al Diritto: Settimanale di approfondimento giuridico*, Dossier n.5, Novembre 2024.
- Iaselli M. (2024) "La procedura di salvaguardia progettata per mitigare i rischi", *Guida al Diritto: Settimanale di approfondimento giuridico*, Dossier n.5, Novembre 2024.
- Iaselli M. (2024) "Monitoraggio post-vendita per un sistema più efficiente. I controlli successivi", *Guida al Diritto: Settimanale di approfondimento giuridico*, Dossier n.5, Novembre 2024.
- International Organization for Standardization, ISO 27005:2022 "Information security, cybersecurity and privacy protection — Information security management systems — Requirements", 2022-10.
- International Organization for Standardization, ISO 9001:2015 "Quality management systems — Quality management systems — Requirements", 2015-09.
- Limone, E. "Aspetti tecnici della cybersecurity", 2024.
- Limone, E. "Come cambierà la ISO 9001?", 2024.
- Limone, E. "Conflitti cibernetici e cybersecurity", 2024.

- Limone, E. “Direttiva NIS2: obiettivi, finalità, ambito di applicazione”, 2024.
- Limone, E. “Protezione dei dati in ambito sanitario e misure di sicurezza e aspetti tecnici”, 2024.
- Pelino, E. (2023) “Algoritmi di sorveglianza e diritti dei lavoratori: i chiarimenti del Garante”, *Cybersecurity360*, 2 febbraio 2023. Consultato online il 30 gennaio 2025.
- Politecnico di Milano, Bertelè, U. & Piva, A. (n.d.). Beyond cybersecurity: tra intelligenza umana e fattore artificiale. In Osservatorio Cybersecurity & Data Protection. *Polimi School of Management*. Consultato online il 10 febbraio 2025, <https://www.osservatori.net/cybersecurity-data-protection>
- Roma, G. et alii, (2023) “Tra GDPR e Statuto dei lavoratori: i profili di privacy del lavoratore sotto la lente del Garante”, *Cybersecurity360*, 2 ottobre 2023. Consultato online il 23 gennaio 2025.
- Spinelli C. (2023) “Il regolamento (UE) 2022/868 sulla governance dei dati e le sue possibili ricadute sulle misure di inclusione lavorativa delle persone con disabilità”, *Federalismi.it*, 19 aprile 2023.
- Tebano L. (2023) “Poteri datoriali e dati biometrici nel contesto dell’AI Act”, *Federalismi.it*, 18 ottobre 2023.
- Zilio Grandi G. e Zanella E. (2022) “Il lavoro “digitale” e non nei processi di riorganizzazione dell’impresa, tra gestione dei dati e datori di lavoro algoritmici” *Federalismi.it*, 27 Luglio 2022.

Forum ICT Security

23^a Edizione

Auditorium della Tecnica, Roma

Novembre

19 e 20 NOVEMBRE 2025

**08 am -
04 pm**

Iscriviti sul sito web:

ictsecuritymagazine.com